

Applied Cybersecurity Workshop

Building a Security & Data Protection Program

Organization Profile

NorthPeak Payments processes credit and debit card payments for small-business clients. The engineering culture is fast-moving and mostly remote — most staff use their own personal laptops (BYOD) unless they're in a customer facing role. The company recently raised funding and is adding new cloud services nearly every week.

Asset List

Your team's job is to work through this list — some assets may not be as safe as they seem.

Asset

- 1 Payment processing database (cloud-hosted; stores cardholder data and payment tokens)
- 2 Core payment API servers (internet-facing cloud VMs)
- 3 Employee laptops (BYOD; a mix of Mac, Windows, and Linux, with minimal central management)
- 4 Engineering staging server (mirrors production; used to test new features before release)
- 5 Customer support ticketing tool (SaaS; stores customer names, emails, and support tickets)
- 6 Internal team chat workspace (company-wide communications)
- 7 Marketing analytics dashboard (SaaS; tracks website visitor behavior)
- 8 An engineer's personal cloud storage account, used informally to share code snippets and CSV data exports with outside contractors

Cybersecurity Foundations – Applied Workshop

Asset

9 Source code repository (private repo, hosted by a third-party git provider)

10 HR/payroll system (SaaS; stores employee SSNs and bank account details)

11 An old prototype payment gateway server from the company's earliest pilot program — still running in a cloud account nobody actively monitors

12 Company handbook and public marketing website content

Regulatory Context

NorthPeak processes cardholder data, so PCI-DSS is the primary regulation. Some of NorthPeak's small-business clients are based in the UK/EU, so GDPR likely applies to those customers' data as well. HIPAA does not apply — NorthPeak does not handle health information.

#	Asset Name	Category	Classification level	Why?	Handling Requirement
1	Payment processing database (cloud-hosted; stores cardholder data and pyt tokens)	data	restricted	This is data with sensitive customer, and payment information.	tokenization
2	Core payment API servers (internet-facing cloud VMs)	software	restricted	Important PII, and financial information.	Encryption in transit
3	Employee laptops(BYOD; a mix of Mac, Windows, and Linux, with minimal central management)	hardware	internal	Its just MDM management of device	Encryption in transit
4	Engineering staging server (mirrors production; used to	hardware	confidential	It is similar to servers holding	Encryption at rest/ and data masking

	test new features before release)			sensitive information, but is for testing purposes	
5	Customer support ticketing tool (SaaS; stores customer names, emails, and support tickets)	software	Confidential	Has customer info, but not sensitive information	Encryption at rest
6	Internal team chat workspace (company-wide communications)	data	internal	Seems to be company only communication	Data masking
7	Marketing analytics dashboard (SaaS; tracks website visitor behavior)	software	internal	Important info to company, but no other real value	Data masking
8	An engineer's personal cloud storage account, used informally to share code snippets and CSV data exports with outside contractors	software	confidential	Could cause harm if exposed(the code snippets, and CSV data)	Encryption in transit
9	Source code repository (private repo, hosted by a third-party git provider)	software	restricted	Could cause severe damage if source code got out	Encryption at rest and at transit
10	HR/payroll system (SaaS; stores employee SSNs and bank account details)	software	restricted	Has employee PII	Encryption in transit and rest
11	An old prototype payment gateway server from the company's earliest pilot program — still running in a cloud account nobody actively monitors	hardware	confidential	Could cause harm if exposed	Encryption at rest

12	Company handbook and public marketing website content	data	public	Open to public no restrictions	No special protection needed
----	---	------	--------	--------------------------------	------------------------------

Hardening Recommendations

Asset	Resource Type	Hardening Techniques (2+)	Why This Asset was Prioritized
Payment processing database	server	Minimize running services, and secure with VPN, or SSH keys	Holds critical payment information of customers
Core payment API servers	server	Enable auditing, and logging, and apply role based access control	Without these the business cannot run
Source code repository	server	Enable role based access, and secure with VPN, or SSH keys	Information that is critical to the business model, or type

a) Secure Baseline

What secure baseline would you build for new employee workstations in this organization? List at least 3 settings or tools it should include.

- MDM
- Firewall configured
- EDR

b) Patch Testing & Scheduling

Describe your patch testing and scheduling approach. How would you handle a critical, actively-exploited vulnerability differently than a routine monthly update?

Use the Vulnerability Handling Lifecycle for critical, actively-exploited vulnerability:

- Discover - flaw surfaces somehow through scan or other means
- Triage - analyze severity, asset, and business impact, decide what to fix first
- Response - apply short-term containment such as closing ports, or blocking access
- Remediation - patch application for long term fix
- Recovery and review - do an after action review, confirm process was followed in change management, look for improvements

Routine monthly updates are handled slightly differently. This uses the non-compressed change management, and testing cycle. Also can apply change at a convenient time for business, such as off-hours (late at night, weekend, etc...). These are not rushed updates, because we want to make sure patch helps, and does not take any critical services down.

c) Patch Management Tooling

Which patch management tool(s) mentioned in lecture would best fit this organization's size and environment? Explain why.

-A good patch management tool for this company would be a cloud based platform like: Intune, Automox, or ManageEngine. These are scaleable, cross-platform with remote patch capabilities. It reduces manual effort, and supports compliance with security policies and frameworks like NIST, or CIS.

Asset Lifecycle Plan

Asset selected for this exercise: Employee laptop

Lifecycle Stage	Action	Security Consideration
Procurement and onboarding	Approve, order, tag, and log each device	Source from trusted vendor, tag for physical, and digital tracking
Configuration and use	Configure, harden, set access, and log activity	Apply hardening and patching before deployment, monitor

		for unauthorized changes
Monitoring and support	Monitor status and compliance, run health checks and updates. Track location	Ensures device stays in compliance, reducing its attack surface, keeping up with updates closes known security holes
End of life - decommissioning	Securely wipe, destroy or recycle hardware, and log disposal record	Ensures no residual data remains

Data Protection Controls

Data/Asset	In Transit, at rest, or both	Best technique	Why this technique fits
Employee laptop	both	Asymmetric key	employees likely will be using the internet to work, and upload work. May have sensitive data that needs to be transmitted
Engineering staging server	At rest	Symmetric key	This server is for testing but is for internal operations of business only and should not be transmitting across the internet
Payment processing database	both	tokenization/encryption	Replaces sensitive data with a token that has no value, used in pyt. System processing

Masking might be ok for the employee chat workspace. It appears to be an internal blog, or communication platform, so (hopefully), no sensitive data is being shared, but info is relevant to company employees, so encryption is not necessary, and no card information, or other sensitive data should be disclosed, so no need for tokenization.

DLP & Shadow IT Strategy

a) Find the Shadow IT Risk

Identify the Shadow IT risk hidden in your scenario. Explain why it's a risk to the organization.

The shadow IT risk is the engineer's personal cloud storage account, used informally to share code snippets, and CSV data exports with outside contractors. It's a risk to the organization because cloud service used by employee is being used by employee without knowledge or approval of the IT dept. This bypasses the security controls, introduces unknown vulnerabilities, and raises the risk of data leaks and non-compliance.

b) Propose a DLP Rule

Propose a specific DLP rule or policy that would have caught this risk (or a similar data leak). Be specific about what it should watch for and what action it should take.

Enforcing a rule requiring a DLP tool such as Microsoft Purview, Symantec DLP, or others that would monitor data movements across email, USB drives, cloud apps, and end points. It would detect or spot patterns or keywords like SS#s, CC#s as confidential, and would respond by blocking the transfer, quarantine, or encrypting file, or redact content.

c) Recommend a Detection Method

Recommend one detection method — network monitoring, DLP alerting, or application allow-listing — and describe how you'd roll it out without disrupting legitimate work.

I would recommend DLP alerting. First choose a DLP tool (one from the previous question), then go through the change management process to ensure that it will work, and serve the company's needs. Do all necessary changes and configurations, and then inform employees of coming changes before implementing a good down time such as late, or a weekend.

Regulatory Compliance & EDR Strategy

a) Which Regulations Apply?

Which regulation(s) apply to your organization — HIPAA, GDPR, PCI-DSS, more than one, or none? Justify your answer using specific details from your scenario.

-This organization handles credit cards, so PCI-DSS is very applicable. This organization does business in Europe, so GDPR is also relevant. PCI-DSS applies to any organization that processes, stores, or transmits payment card data. GDPR protects personal data of individuals in the EU. It applies to any organization processing EU residents' data regardless of location (some clients of the company are in the UK/EU).

b) Required Controls

List two specific controls your organization must implement to meet the regulation(s) you identified.

-Two controls that must be implemented are encryption of credit card data, and maintaining of secure systems through logs, IDS, firewalls, least privilege, and access control.

c) EDR Strategy

Describe how an EDR solution would improve this organization's visibility and incident response. Reference the hidden risk you found in Part 6 — how would EDR have helped catch it sooner?

An EDR tool like: CrowdStrike Falcon, SentinelOne Singularity, or Microsoft Defender for Endpoint would help this organization by continuously monitoring employee devices, including remote and BYOD endpoints for suspicious activity. It can perform malware scans, detect unusual login behavior, and other signs of compromise. It can also alert security, isolate a device, investigate, therefore reducing potential impact of a breach.

Final Deliverable: Executive Summary

Top 3 Risks You Found

- Employee laptops with minimal central management
- The engineer's personal cloud storage account
- the old prototype payment gateway server - that's still running in a cloud account.

Top 3 Recommended Actions

- Implement MDM and enforce policies

- Block engineer's personal cloud storage account from any company servers or workstations
- De-commission the old prototype gateway server

-This is a small, but quickly scaling card processing company that does not appear to have much central management of data, server's, or devices. BYOD is an OK policy, but ideally employees should have company issued laptops for work that are pre-configured with a secure baseline, hardened, and consistent. This makes it easier to monitor, maintain, and audit. All the employee devices create a space for Shadow IT, which can introduce vulnerabilities. Old devices (such as the old prototype gateway server), it not necessary to current business operations should be audited, and decommissioned. This company maintains sensitive PII, and has many regulatory, and compliance regulations it has to adhere to (such as PCI-DSS, and GDPR), so starting by "getting everyone on the same page", and ensuring that employees are aware of rules, laws, and compliance through training is vitally important. Also, investment into cybersecurity tools, such as DLP, EDR, IDS, MFA, patching tools, cloud security, and others ensures that the company will do its utmost to protect customer data, and save itself from any potential harm that might come from a breach. Although it's impossible to prevent everything, the company should do everything in its power to be as secure as possible. What we do not want is a loss of trust because of exposure of credit card data, due to some employee introducing malware, or be more susceptible to a breach because of an unwatched system like the old prototype gateway server.